

Incident Investigation Report – Orion Health Services

Executive Summary

Orion Health Services experienced a ransomware attack that resulted in the encryption of critical systems and unauthorised access to sensitive data. Initial investigation indicates the attack originated from a phishing email sent to a finance department employee. The malicious Excel attachment allowed attackers to gain access to the network, harvest credentials, and deploy ransomware across multiple systems.

The attack impacted business operations and exposed confidential employee and patient-related information. Immediate containment and recovery actions were initiated by the cybersecurity team.

Attack Timeline

- Morning: Unusual outbound traffic detected from internal server
- Midday: Employees reported being locked out of systems
- Midday: Ransom note discovered on shared drive
- Investigation: Phishing email identified as initial attack vector
- Investigation: Credential theft activity discovered using Mimikatz

Initial Entry Point

The attackers gained access through a phishing email sent to a finance team employee.

- Email contained a malicious Excel attachment.
- User opened the attachment, executing malicious code.
- Malware established persistence within the network.
- Attackers escalated privileges and moved laterally across systems.

Systems Affected

- File Server
- HR System
- Finance System
- Backup Server (partially encrypted)

Compromised Data

- Employee payroll records
- Patient appointment schedules
- Internal system credentials

Indicators of Compromise (IOCs)

- Suspicious login activity from an overseas IP address
- Execution of Mimikatz credential harvesting tool
- Files encrypted with the .orionlock extension
- Unusual outbound network traffic
- User account lockouts

Impact Assessment

Confidentiality Impact:

- Exposure of employee payroll information
- Exposure of patient scheduling data
- Theft of user credentials

Integrity Impact:

- Unauthorised modification and encryption of files

Availability Impact:

- Loss of access to critical business systems
- Operational disruption for HR and finance teams

Immediate Response Actions

1. Isolate affected systems from the network.
2. Disable compromised user accounts.
3. Block malicious IP addresses.
4. Preserve logs and evidence for forensic analysis.
5. Scan all endpoints for malware.
6. Restore systems from clean backups.
7. Reset all potentially compromised credentials.
8. Notify management and relevant regulatory authorities if required.

Recommendations

- Implement Multi-Factor Authentication (MFA).
- Conduct regular phishing awareness training.
- Apply security patches promptly.
- Restrict administrative privileges.
- Deploy Endpoint Detection and Response (EDR) solutions.
- Maintain offline and immutable backups.
- Monitor network traffic continuously.
- Perform regular security audits and penetration testing.

Conclusion

The ransomware attack was initiated through a phishing email and resulted in the compromise of sensitive data and disruption of critical business systems. Rapid containment, recovery, and strengthened security controls are necessary to restore operations and prevent future incidents. The incident highlights the importance of employee security awareness, robust monitoring, and effective backup strategies.